Conceção, Implementação e Avaliação Experimental de um Sistema de Streaming Seguro

Trabalho Prático: WA1
Autores: Rodrigo Simões nº77481

Resumo

O presente relatório descreve o desenvolvimento e a avaliação de uma solução de streaming seguro, realizada no âmbito do primeiro trabalho prático da unidade curricular de Segurança de Sistemas de Computadores. O objetivo consistiu em acrescentar mecanismos de proteção criptográfica a uma arquitetura de transmissão de vídeo inicialmente desprotegida, composta por um servidor de streaming e um proxy responsável pelo encaminhamento dos conteúdos para um navegador web.

A solução desenvolvida estabelece um canal de comunicação seguro entre o Proxy e o servidor, recorrendo ao protocolo de troca de chaves X25519, a assinaturas digitais Ed25519, à função de derivação de chaves HKDF e ao algoritmo AES-GCM para cifragem autenticada. Estes mecanismos permitem proteger a confidencialidade e a integridade dos dados transmitidos, autenticar a identidade do servidor e detetar tentativas de repetição, alteração ou reordenação de mensagens.

A implementação suporta três configurações criptográficas, AES-128-GCM, AES-192-GCM e AES-256-GCM, selecionadas através de ficheiros XML externos, sem necessidade de recompilar o código. A validação incluiu testes funcionais, testes de segurança e experiências de transmissão de vídeo através de um navegador.

Os resultados demonstraram o funcionamento das três configurações, a rejeição de propostas criptográficas incompatíveis e a correta autenticação e descodificação dos blocos de vídeo recebidos. Os nove programas de teste de segurança executados terminaram com sucesso.

1. Introdução

A transmissão de conteúdos multimédia através de redes de computadores coloca desafios relacionados com a proteção dos dados e a autenticidade das entidades envolvidas na comunicação. Num sistema de streaming sem mecanismos criptográficos, um atacante com acesso ao tráfego de rede pode intercetar os conteúdos transmitidos, modificar mensagens ou tentar reproduzir blocos anteriormente enviados.

O projeto 3S (*Secure Streaming Solution*) procura responder a estes problemas através da implementação de um protocolo de comunicação seguro, aplicado a uma arquitetura de streaming previamente disponibilizada. Esta arquitetura é constituída por um servidor responsável pelo fornecimento de conteúdos multimédia e por um Proxy que recebe os dados e os encaminha para um navegador web.

Na implementação original, a comunicação entre o Proxy e o servidor não oferecia garantias de confidencialidade, integridade ou autenticidade. Assim, o principal objetivo deste trabalho foi introduzir mecanismos criptográficos capazes de proteger a transmissão dos conteúdos, mantendo a funcionalidade de reprodução de vídeo.

Para concretizar este objetivo, foi desenvolvido um processo de estabelecimento de sessão baseado numa troca de chaves autenticada, seguido da utilização de cifragem

autenticada para proteger os blocos de dados transmitidos. Foram igualmente implementados mecanismos de controlo da sequência das mensagens, permitindo detetar tentativas de repetição e alterações à ordem esperada dos blocos.

Outro requisito importante consistiu na possibilidade de alterar os parâmetros criptográficos através de ficheiros de configuração, sem modificar o código-fonte. Neste contexto, foram implementadas e testadas três configurações AES-GCM com diferentes tamanhos de chave.

O trabalho corresponde à primeira fase do projeto 3S, centrando-se na comunicação segura entre o Proxy e o servidor de streaming. A autenticação de utilizadores através de um servidor de autenticação independente será abordada numa fase posterior.

2. Arquitetura do Sistema

2.1. Organização geral

A solução desenvolvida mantém a arquitetura base disponibilizada no enunciado, introduzindo uma camada de comunicação segura entre o Proxy e o servidor de streaming.

O sistema é constituído por três componentes principais: o *Secure Stream Server*, o *Secure Proxy* e um módulo partilhado que reúne as funcionalidades criptográficas e de comunicação.

O Secure Stream Server é responsável por disponibilizar os ficheiros multimédia e transmitir os respetivos blocos através do canal seguro. Antes de iniciar a transmissão, participa no processo de negociação criptográfica e estabelecimento das chaves de sessão.

O Secure Proxy estabelece a ligação ao servidor, participa no processo de autenticação e negociação, recebe os blocos cifrados, verifica a sua autenticidade e integridade e encaminha os dados decifrados para o navegador web.

O módulo partilhado contém as classes responsáveis pelo protocolo de handshake, troca e derivação de chaves, assinaturas digitais, proteção dos registos e gestão do canal seguro. Esta organização permite reutilizar os mesmos mecanismos nos dois extremos da comunicação, reduzindo a duplicação de código.

2.2. Fluxo de comunicação

Durante os testes, o Secure Stream Server foi executado na porta TCP 8081 e o Secure Proxy disponibilizou uma interface HTTP local na porta 8080.

O funcionamento geral inicia-se quando o navegador solicita um conteúdo multimédia ao Proxy. Este estabelece uma ligação ao servidor de streaming e inicia o protocolo de handshake. Depois de concluída a autenticação e estabelecidas as chaves de sessão, o servidor transmite os blocos protegidos criptograficamente.

À medida que recebe os blocos, o Proxy verifica a sua autenticidade, decifra o conteúdo e encaminha os dados para o navegador, permitindo a reprodução do vídeo.

A proteção criptográfica implementada aplica-se à comunicação entre o Secure Proxy e o Secure Stream Server. A ligação HTTP local entre o navegador e o Proxy não é protegida pelo protocolo desenvolvido neste trabalho.

3. Estabelecimento do Canal Seguro

3.1. Protocolo de handshake

Antes da transmissão dos conteúdos multimédia, o Proxy e o servidor executam um protocolo de handshake destinado a negociar os parâmetros criptográficos e estabelecer as chaves necessárias à comunicação segura.

O processo começa com uma mensagem enviada pelo Proxy, contendo a proposta de configuração criptográfica e os dados necessários ao estabelecimento da sessão.

O servidor verifica se a configuração proposta é compatível com os parâmetros definidos no seu ficheiro XML. Caso exista incompatibilidade, o estabelecimento da sessão é rejeitado.

Quando a proposta é aceite, os participantes prosseguem com a troca de informação criptográfica e a autenticação do servidor. O processo termina com uma mensagem de confirmação, que permite verificar a consistência do estado criptográfico estabelecido.

3.2. Troca de chaves X25519

Para estabelecer um segredo partilhado, foi utilizado o protocolo de troca de chaves X25519, baseado em criptografia de curva elíptica.

Cada participante gera um par de chaves efémeras e utiliza a chave pública recebida da outra entidade para calcular um segredo partilhado. Quando o protocolo é executado corretamente, ambos obtêm o mesmo segredo sem necessidade de o transmitir diretamente pela rede.

A utilização de chaves efémeras contribui para a propriedade de *forward secrecy*, uma vez que as chaves utilizadas numa sessão não precisam de ser reutilizadas nas sessões seguintes.

No entanto, a troca de chaves Diffie–Hellman, por si só, não autêntica os participantes. Por esse motivo, foi necessário acrescentar um mecanismo de autenticação ao handshake.

3.3. Autenticação com Ed25519

A autenticação da identidade do servidor é realizada através de assinaturas digitais Ed25519.

O servidor utiliza a sua chave privada de identidade para assinar informação relevante do handshake. O Proxy verifica a assinatura com uma chave pública previamente considerada confiável.

Este mecanismo permite detetar tentativas de substituição da identidade do servidor ou de alteração dos dados autenticados durante o estabelecimento da sessão.

Nos testes realizados, foram rejeitadas assinaturas modificadas, dados alterados e identidades incorretas.

3.4. Derivação de chaves com HKDF

Após a troca de chaves X25519, o segredo partilhado é utilizado como entrada para o mecanismo HKDF, responsável pela derivação das chaves simétricas utilizadas na comunicação.

Foram definidas chaves distintas para cada sentido da ligação: uma para a comunicação do Proxy para o servidor e outra para a comunicação do servidor para o Proxy.

Esta separação evita a utilização da mesma chave nos dois sentidos e contribui para uma organização mais segura do canal.

O tamanho das chaves derivadas depende da configuração negociada, permitindo utilizar AES com 128, 192 ou 256 bits.

3.5. Proteção dos blocos com AES-GCM

Depois de estabelecido o canal seguro, os dados são protegidos através de AES em modo GCM (*Galois/Counter Mode*).

Este modo de funcionamento combina cifragem e autenticação numa única construção criptográfica, conhecida como AEAD (*Authenticated Encryption with Associated Data*).

A cifragem protege a confidencialidade dos conteúdos, enquanto a autenticação permite detetar modificações não autorizadas aos registos transmitidos.

A implementação utiliza vetores de inicialização de 96 bits e valida os registos recebidos antes de disponibilizar o respetivo conteúdo ao processamento seguinte.

O protocolo inclui ainda mecanismos de controlo da sequência dos registos, permitindo rejeitar mensagens repetidas ou recebidas fora da ordem esperada.

4. Configuração Criptográfica

Uma das características da solução desenvolvida é a possibilidade de selecionar os parâmetros criptográficos através de ficheiros de configuração externos.

O Proxy utiliza o ficheiro proxycrypto.config, enquanto o servidor utiliza sservercrypto.config. Ambos definem os parâmetros necessários ao estabelecimento do canal seguro.

Foram testadas três configurações baseadas em AES-GCM:

Configuração	Tamanho da chave	Tamanho do IV	Resultado
AES-128-GCM	128 bits	96 bits	Transmissão bem-sucedida
AES-192-GCM	192 bits	96 bits	Transmissão bem-sucedida
AES-256-GCM	256 bits	96 bits	Transmissão bem-sucedida

A alteração entre configurações foi realizada exclusivamente através da modificação dos ficheiros XML e do reinício dos componentes, sem necessidade de recompilar o código Java.

Foi também realizado um teste de incompatibilidade, configurando o Proxy com AES-128-GCM e o servidor com AES-256-GCM.

Neste cenário, o servidor identificou a diferença entre os parâmetros propostos e os suportados, rejeitando o handshake. Como consequência, o vídeo não foi transmitido.

Este comportamento demonstra que a negociação criptográfica verifica a compatibilidade das configurações antes de permitir o estabelecimento do canal.

5. Modelo de Ameaças e Análise de Segurança

5.1. Capacidades do atacante

O modelo de ameaças considera um atacante com capacidade para observar e interferir no tráfego de rede entre o Proxy e o servidor.

O atacante pode intercetar, modificar, inserir, repetir, reordenar ou eliminar mensagens durante a comunicação.

Admite-se, contudo, que os sistemas finais não foram comprometidos e que o atacante não possui as chaves privadas legítimas nem consegue quebrar diretamente os algoritmos criptográficos utilizados.

5.2. Ameaças e mecanismos de proteção

Ameaça	Mecanismo de proteção	Resultado esperado
Interceção de tráfego	Cifragem AES-GCM	Proteção da confidencialidade
Modificação de mensagens	Autenticação AES-GCM	Deteção de alterações
Falsificação de mensagens	Cifragem autenticada	Rejeição de registos inválidos
Repetição de mensagens	Números de sequência	Rejeição de mensagens repetidas
Reordenação de blocos	Controlo de sequência	Deteção de ordem incorreta
Falsificação da identidade do servidor	Assinaturas Ed25519	Rejeição de identidade incorreta
Ataque man-in-the-middle	Troca de chaves autenticada	Proteção do estabelecimento da sessão
Comprometimento de uma chave de sessão	Chaves efémeras por sessão	Limitação do impacto entre sessões
Eliminação de mensagens	Controlo da sequência e ligação	Deteção possível, sem garantir disponibilidade
Negação de serviço	Sem mecanismo específico demonstrado	Fora do âmbito da implementação

5.3. Forward secrecy

A utilização de pares de chaves efémeras X25519 permite estabelecer segredos diferentes entre sessões independentes.

Assumindo que são geradas novas chaves efémeras e que os respetivos valores privados não são conservados, o comprometimento posterior da chave privada de assinatura do servidor não deverá permitir recuperar diretamente as chaves de sessões anteriores.

Esta propriedade não impede, contudo, que um atacante com acesso à chave de uma sessão ativa consiga comprometer os dados protegidos por essa chave.

6. Implementação e Testes de Segurança

A implementação foi desenvolvida em Java, utilizando o JDK 27 e o ambiente IntelliJ IDEA.

A validação dos mecanismos de segurança foi realizada através de nove programas de teste, destinados a verificar diferentes componentes do protocolo.

Teste	Funcionalidade verificada	Resultado
HandshakeMessageTest	Estrutura e interpretação das mensagens	Aprovado
KeyDerivationTest	Derivação de chaves e separação por direção	Aprovado
KeyExchangeTest	Troca de chaves X25519	Aprovado
DigitalSignatureTest	Assinaturas Ed25519	Aprovado
HandshakeProtocolTest	Funcionamento do handshake	Aprovado
HandshakeSecurityTest	Rejeição de alterações ao handshake	Aprovado
SecureHandshakeTest	Handshake autenticado através de TCP	Aprovado
SecureRecordTest	Cifragem, integridade e proteção contra replay	Aprovado
SecureChannelTest	Comunicação através do canal seguro	Aprovado

Os testes de segurança confirmaram a rejeição de mensagens modificadas, assinaturas inválidas, identidades incorretas, registos repetidos e blocos recebidos fora da sequência esperada.

Os nove programas terminaram com sucesso, sem erros de execução.

Embora estes resultados constituam evidência do funcionamento dos mecanismos implementados, não representam uma prova formal da segurança do protocolo.

7. Avaliação Experimental

7.1. Ambiente de testes

Os testes experimentais foram realizados num ambiente local Windows, utilizando o JDK 27.

O servidor de streaming foi executado na porta 8081 e o Proxy na porta 8080. A reprodução do vídeo foi efetuada através de um navegador web, utilizando o endereço http://localhost:8080.

O ficheiro multimédia utilizado foi sample.mp4, com um tamanho original de 2 899 886 bytes.

7.2. Resultados da transmissão

Durante uma experiência com AES-256-GCM, foram registados os seguintes valores:

Métrica	Valor observado
Tamanho original do ficheiro	2 899 886 bytes
Código HTTP	206 Partial Content
Blocos cifrados recebidos	3 359
Blocos decifrados encaminhados	3 359

Dados autenticados recebidos	1 720 238 bytes
Dados encaminhados	1 720 238 bytes
Duração da transferência	0,453 s
Throughput observado	3 796,17 kB/s

A correspondência entre o número de blocos recebidos e encaminhados indica que todos os blocos autenticados nesta transferência foram processados e enviados para o navegador.

O throughput foi calculado a partir do volume de dados multimédia encaminhados e do tempo de transferência medido pelo Proxy. Esta medição não inclui os cabeçalhos HTTP nem a sobrecarga dos registos cifrados.

7.3. Comparação com o ficheiro original

O volume de dados encaminhado foi inferior ao tamanho total do ficheiro multimédia, correspondendo a aproximadamente 59,32% do seu tamanho original.

Esta diferença está relacionada com o código HTTP 206 Partial Content, que indica uma transferência parcial do recurso solicitado.

Assim, a diferença entre os dois valores não deve ser interpretada como perda de dados, uma vez que o navegador não solicitou necessariamente a totalidade do ficheiro durante a experiência observada.

7.4. Comparação entre configurações

Foram também recolhidas medições durante a transmissão do mesmo conteúdo com diferentes tamanhos de chave AES.

Configuração	**Dados encaminhados**	**Duração**	**Throughput**
AES-128-GCM	1 720 238 bytes	0,220 s	7 831,09 kB/s
AES-192-GCM	1 720 238 bytes	0,288 s	5 968,81 kB/s
AES-256-GCM	1 720 238 bytes	0,453 s	3 796,17 kB/s

As três configurações permitiram transmitir corretamente o conteúdo solicitado.

Apesar das diferenças observadas no throughput, os resultados correspondem a execuções individuais e não permitem concluir que uma configuração seja sistematicamente mais rápida do que outra.

Uma comparação de desempenho mais rigorosa exigiria várias repetições de cada experiência, em condições controladas, permitindo calcular médias e medidas de dispersão.

8. Limitações e Trabalho Futuro

Apesar dos resultados obtidos, a solução apresenta algumas limitações.

A implementação suporta diferentes tamanhos de chave AES, mas não foi demonstrado o funcionamento de algoritmos alternativos, como ChaCha20-Poly1305.

A proteção criptográfica aplica-se apenas ao canal entre o Proxy e o servidor. A ligação local entre o navegador e o Proxy utiliza HTTP e não beneficia diretamente dos mecanismos de cifragem desenvolvidos.

A autenticação de utilizadores através de um Authentication Server não foi implementada nesta fase, uma vez que corresponde a um objetivo do trabalho seguinte.

A avaliação experimental foi realizada num ambiente local, com medições individuais. Seria relevante alargar os testes a diferentes condições de rede, ficheiros de maior dimensão e múltiplos clientes simultâneos.

Como trabalho futuro, poderão também ser melhoradas as mensagens de diagnóstico e introduzidos testes adicionais de robustez perante interrupções inesperadas das ligações.

9. Conclusão

O desenvolvimento do projeto 3S permitiu acrescentar mecanismos de comunicação segura a uma arquitetura de streaming inicialmente desprotegida.

A solução implementada utiliza X25519 para estabelecimento de segredos partilhados, Ed25519 para autenticação da identidade do servidor, HKDF para derivação de chaves e AES-GCM para proteção dos dados transmitidos.

Os testes realizados confirmaram o funcionamento do canal seguro e a rejeição de diferentes tentativas de manipulação das mensagens. Foi igualmente possível transmitir e reproduzir conteúdos multimédia através de um navegador web, mantendo a proteção criptográfica entre o Proxy e o servidor.

Outro resultado relevante foi a implementação de três configurações AES-GCM, com chaves de 128, 192 e 256 bits, selecionadas através de ficheiros externos sem recompilação. A rejeição de configurações incompatíveis demonstrou também a existência de validação dos parâmetros durante o estabelecimento da sessão.

Conclui-se que os principais mecanismos de segurança desenvolvidos funcionaram corretamente nos cenários testados, constituindo uma base para a evolução do sistema nas fases seguintes do projeto.

Referências Bibliográficas

[1] Computer Systems Security. *Work Assignment #1 — 3S: Secure Streaming Solution, Part I*. Ano letivo 2026/2027.

[2] NIST. *FIPS 197 — Advanced Encryption Standard (AES)*.

[3] NIST. *SP 800-38D — Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC*.

[4] IETF. *RFC 7748 — Elliptic Curves for Security*.

[5] IETF. *RFC 8032 — Edwards-Curve Digital Signature Algorithm (EdDSA)*.

[6] IETF. *RFC 5869 — HMAC-based Extract-and-Expand Key Derivation Function (HKDF)*.